Evaluation Plan

Metrics, data, baselines, ablations and how results are reported

1. Questions the evaluation must answer

- Does AIDDS catch hijacked agents that permission checks miss? How early?
- How many false alarms does it raise on legitimate change and new agents?
- Which signals matter? Does removing any one of them hurt?
- Can an evasive attacker get under the threshold?

2. Metrics

Metric	Definition	Target
Recall	Attack scenarios that reach their expected tier / all attack scenarios	0.90 or higher
False-positive rate	Benign scenarios that reach tier 40 or above / all benign scenarios	0.05 or lower
Time to detect (TTD)	Events between the first malicious action and the first alert at the expected tier	3 events or fewer
Data exposed before block	Records or bytes that left before restriction	Zero for S01 and S07
Inline latency	Gateway decision time, p50 and p95	p95 under 10 ms
Collateral impact	Legitimate calls blocked on other agents during isolation	Zero

3. Data

- **Benign traffic:** simulator generates role-specific normal sessions with noise (volume swings, new tools via manifest change, new agents). Target 2,000 or more sessions across 3 roles.
- **Attack traffic:** scenarios S01 to S09 with randomised timings, resource names and payload sizes. Target 20 or more variants per scenario.
- **Split:** tune thresholds on one set, report on a held-out set generated with different seeds. Never report numbers from the tuning set.

4. Baselines to beat

Baseline	What it represents
Permission check only	Today's IAM: valid token and scope means allowed
Static allowlist	Manifest rules without any learning or taint
Per-agent z-score	Classic anomaly detection on call counts, no role or taint
AIDDS (full)	All signals plus overrides

5. Ablations and stress tests

- **Ablation:** remove one signal at a time (taint, rules, Markov, semantic, CUSUM) and report the change in recall and FPR.
- **Evasion:** attacker copies normal frequencies (S06), spreads actions slowly (S05), stays under a guessed threshold. Report the lowest score reached and whether the override or honeypot still fired.
- **Cold start:** measure recall and FPR for agents with 0, 10, 100 and 1,000 prior events.
- **Load:** 1,000 events per second per node; report latency and dropped events.

6. Reporting

- `python -m eval.run` writes `eval/report.json`; the CI gate reads it.
- Final report: one results table (baselines vs AIDDS), one ablation table, one score-over-time plot for S01, and a short limitations paragraph.
- Fix random seeds and publish them so results can be reproduced.